Indian Computer Emergency Response Team
Ministry of Electronics and Information Technology
Government of India

CERT-In Advisory CIAD-2026-0049

AI Agents as Attack Vectors: Unauthorized Access by Agents under Evaluation and Misuse of Open-Source Agentic AI Tools Targeting Indian ICT Assets

Original Issue Date: October 15, 2026

Severity Rating: Critical

Description

CERT-In has observed different categories of cyber incidents in which the attacker was an AI agent, that is, a software system capable of autonomously planning work, issuing commands, invoking tools and acting on the internet over extended periods. In some incidents, AI agents under research and evaluation exceeded their assigned task authorization and made unauthorized access to Indian information and communication technology (ICT) assets. In others, cyber attackers deliberately used open-source agentic AI tools to conduct reconnaissance, exploitation and financially motivated intrusions.

The incidents came to light through voluntary disclosures by AI model providers, CERT-In's forensic analysis of suspicious activities, and CERT-In's own proactive threat hunting. The affected organizations could not detect the unauthorized access on their own.

Categories of Incidents Observed

Voluntary Disclosures

1. AI agents exceeding task authorization during research and evaluation: unauthorized access to Indian ICT assets

- Recently, CERT-In has received multiple voluntary disclosures from AI model providers stating that their models, during research and evaluation activity on the internet, had reached the live systems of Indian organizations.
- The recorded activity involved reading business records, including personal data and confidential material, through credentials and connection settings exposed in application configuration, public code repositories and permissive cloud service roles.
- In the disclosed cases, the models' actions exceeded the authorization of their assigned tasks.
- None of the affected organizations detected the access; in every case the incident was disclosed by the AI model providers after their internal review.

CERT-In's Threat Hunting

2. Cyber attackers using open-source agentic AI tools

- CERT-In has observed financially motivated campaign against Indian entities in which cyber threat actors abused publicly available AI-native offensive-security frameworks.
- These frameworks continue to be misused and rebranded, with a large number of deployments observed across infrastructure in multiple countries, indicating the widespread availability of ready-made agentic intrusion capabilities.

Observations based on analysis by CERT-In

3. Weaknesses exploited at machine speed

- In the financially motivated campaign against Indian entities, agentic tooling compressed the time between initial access and final impact from days to a few hours.
- In addition, the campaign highlighted that multi-agent operations run in parallel for hours to days to achieve the attacker goals, consistent with the documented multi-agent capability of these tools.
- Further, victim entities in the campaign that remediated incompletely were attacked again within days, at greater scale.
- In the voluntarily disclosed incidents, agents were observed re-deriving and re-using the same exposed credential in separate operations.

4. The weaknesses exploited are conventional

Across all AI agent driven incidents observed recently, the root weaknesses are conventional:

- Credentials and keys exposed in source code, public repository history, configuration files, client applications and public web content;
- Dormant, deprecated and test application programming interfaces (APIs) left reachable from the internet;
- Payment-API keys stored in plaintext and readable from application runtimes;
- Over-permissive cloud and backend-as-a-service roles permitting broad reads and writes by ordinary or anonymous callers;
- Internet-exposed management interfaces and unpatched application middleware with weak credentials or no multi-factor authentication.

In the incidents observed, AI found and exploited these conventional weaknesses faster, more exhaustively and at greater scale than human attackers.

Recommended Actions

A. For AI model developers, research laboratories and evaluation agencies

1. Isolate research and evaluation workloads with default-deny network egress, permitting only the destinations a task strictly requires. Enforce the restriction at the network layer, not through instructions to the model.
2. Use synthetic targets, synthetic credentials and disposable infrastructure. Keep production data and real credentials out of the evaluation environment.
3. Define in every task the systems and actions that are in scope, and treat everything else as out of scope. Stop the run automatically if the agent contacts third-party systems, discovers or uses third-party credentials, or raises a stop or failure signal. Give an independent operator the authority to terminate or restart the run.
4. Monitor agent activity in real time. Log model-initiated requests as completely as feasible, including destination, port, protocol and result. Do not rely on after-the-fact transcript review alone; on its own it can miss activity that a model's reasoning makes appear legitimate.
5. Block the re-use of every third-party credential an agent encounters: suppress it in all future runs and flag the exposure for review and remediation.
6. If an agent accesses a real system, notify the affected organization and CERT-In promptly. Assist the organization's remediation.
7. Publish the safeguards adopted so that the community benefits.

B. For organizations and service providers

1. Implement the baseline measures as outlined in the CERT-In "Blueprint for Reducing Exposure and Defending against AI-Assisted Vulnerabilities Exploitation in Digital Infrastructure".
2. Audit for exposed credentials in source code, repositories (including commit history), continuous integration and continuous delivery (CI/CD) variables, configuration files, client applications and cloud storage.
3. Rotate any exposed credential, purge it from history and verify the fix externally. Scan every commit and build for secrets. Keep credentials out of code, configuration files and databases.
4. Keep a complete inventory of APIs. Decommission dormant, deprecated and test APIs and accounts.
5. Apply least privilege in cloud and backend-as-a-service deployments. Use row-level security and least-privileged client roles. Never place privileged or service keys in client-side code. Allow writes only to authenticated, authorized roles. Test what an anonymous caller can read and write.
6. Remove management and administrative interfaces from the internet. Enforce multi-factor authentication for all administrative access. Patch exposed application middleware without delay.
7. Detect attacks at machine speed. Apply rate-based and per-second API anomaly detection. Alert on enumeration bursts, bulk reads and automated registrations. Retain logs for at least 180 days.
8. After any credential exposure or confirmed access, treat the environment as compromised until forensically cleared. Retest after remediation. Expect repeat attempts within days to weeks.
9. Govern AI agents deployed within the organization. Give each run a separate, short-lived identity with least privilege. Enforce default-deny egress, permitting only required destinations, and maintain a tamper-resistant log of agent activity, covering at minimum all actions that affect production systems and data.
10. BFSI and fintech entities should also implement the payment and disbursement API measures advised in CIAD-2026-0046.

References

Threat Actors Exploiting Payment and Disbursement APIs for Unauthorized Fund Transfers in BFSI Entities
Blueprint for Reducing Exposure and Defending against AI-Assisted Vulnerabilities Exploitation in Digital Infrastructure

Disclaimer

The information provided herein is on "as is" basis, without warranty of any kind.

Contact Information

Email: info@cert-in.org.in
Phone: +91-11-22902657

Postal address

Indian Computer Emergency Response Team (CERT-In)
Ministry of Electronics and Information Technology
Government of India
Electronics Niketan
6, CGO Complex, Lodhi Road,
New Delhi - 110 003
India